

NYPD SECURITY REQUIREMENTS FOR CLOUD SERVICES PROVIDERS

I. DEFINITIONS

- 1.1. **“City”** means the City of New York, including all of its counties, boroughs, offices, positions, administrations, departments, divisions, bureaus, boards, commissions, corporations, institutions, or agencies and their respective personnel.
- 1.2. **“NYPD Data”** means (1) Data characterizing the NYPD or its behavior; (2) Data created, generated, stored or maintained by, at the direction of, or for the benefit of the NYPD; and (3) any copies or derivatives of such Data.
- 1.3. **“City Technology Assets”** means all City facilities, City systems, City telecommunications, electronic data created, processed, accessed, transferred, stored, or disposed of by City systems, and such systems' peripheral equipment, networks, or magnetic data, and any electronic data created, processed, accessed, transferred, stored, or disposed of by such systems.
- 1.4. **“Cloud Service/s”** means the software-, platform-, infrastructure- or other “as a service” solution for which access is provided by Provider including any client software provided by Provider for use with the Cloud Service. Any software to be installed on the NYPD’s hardware for the purpose of facilitating the NYPD’s use of the Cloud Services shall be deemed to be a part of the Cloud Services.
- 1.5. **“Data”** means any information representation(s) of information, facts, concepts or similar including any texts, instructions, documents, databases, diagrams, graphics, drawings, images, sounds, or biometrics that are accessed, communicated, created, generated, stored (in temporary or permanent form), filed, produced or reproduced, processed, referenced, or transmitted, in any form or media.
- 1.6. **“Intellectual Property Rights”** or **“Intellectual Property”** means all proprietary information, patents, patent applications, trademarks, trade names, service marks, certification marks, collective marks, designs, processes, inventions, licenses, copyrights, and trade secrets of either Party, including, but not limited to, such rights relating to the origin, design, manufacture, programming, operations, function, configuration, or service of the licensed product.
- 1.7. **“Non-Public City Data”** means all City Data that is considered Restricted or Sensitive Information as those categories are defined by the City’s Policies and Standards. All Personal Identifying Information (as defined in Section 10-501 of the New York City Administrative Code or successor), Identifying Information (as defined in Section 23-1201 or successor), information protected from unauthorized use or disclosure by local, state or federal law and regulation, the City’s confidential information (including information disclosed or made available by the City in the course of receiving maintenance, subscription and support and other services) and security information is Non-Public City Data.
- 1.8. **“NIST”** means the National Institute of Standards and Technology.
- 1.9. **“Open Source Software”** or **“OSS”** means an open source or other license that requires, as a condition of use, modification, or distribution, that any resulting software must be (a) disclosed or distributed in source code form; (b) licensed for the purpose of making derivative works; or (c) redistributable at no charge.

- 1.10. **“Provider Systems”** means the facilities, systems, networks and IT environments that are used to Process any NYPD Data, deliver any Cloud Services or to otherwise meet any of Provider’s obligations in order to deliver Cloud Services, including, individually or collectively, all network addressable items in an information technology environment and non-networked items with central processing units. Systems should be construed broadly to include, without limitation, servers, laptops, mainframes, portable computing devices, cloud infrastructure, Internet of Things devices, network appliances, industrial control system devices and supervisory control and data acquisition devices.
- 1.11. **“Security Incident”** means an event that compromises or is suspected to compromise the security, confidentiality, availability or integrity of NYPD Data, City Technology Assets or Provider Systems, including by compromising the physical, technical, administrative or organizational safeguards implemented by Provider to protect the security, confidentiality, availability or integrity of NYPD Data, City Technology Assets or Provider Systems. Examples of a Security Incident include, but are not limited to, the unauthorized acquisition or use of unencrypted NYPD Data (or encrypted NYPD Data and the decryption key), network intrusions, ransomware infections, a breach of access credentials and DoS attacks.

II. DATA MANAGEMENT AND SECURITY

- 2.1. Safeguards to Protect NYPD Data. Provider shall implement and maintain appropriate physical, technical, administrative, and organizational safeguards in accordance with industry best practices and applicable law to protect the security, confidentiality, availability, and integrity of NYPD Data, including, but not limited to, the safeguards described in this document.
- 2.2. Backup and Recovery of NYPD Data. As a part of the Cloud Services provided, Provider is responsible for creating, maintaining, and testing backup copies of NYPD Data. Provider is responsible for an orderly and timely recovery of the Cloud Services and NYPD Data in the event that the Cloud Services are interrupted. Except when shorter time(s) are otherwise provided in a separate agreement, the recovery time objective (“**RTO**”) for Cloud Services is six (6) hours and the recovery point objective (“**RPO**”) for NYPD Data is two (2) hours. For the purpose of calculating the RTO, recovery time is equal to the elapsed period of time between the commencement of an interruption and the time at which the Cloud Service is fully restored and available for use by the NYPD. RPO means the period of time during which changes made to data shall not be included in a replication or other backup copy. Provider shall replicate data to a disaster recovery site that meets the requirements in this document. Provider shall maintain no less than thirty (30) days of backups. Any backups of NYPD Data shall not be considered in calculating storage used by the NYPD.
- 2.3. Disaster Recovery Sites. Provider shall have a minimum of one (1) disaster recovery site at a distance of at least five hundred (500) miles from the primary site. NYPD Data must be replicated from the primary data center to the disaster recovery site in a time and manner sufficient to meet the RPO, and the Cloud Service must be configured to fail over from the primary data center to the disaster recovery site within the RTO. The disaster recovery site must be capable of supporting the Cloud Service at full load. The NYPD shall not incur any costs in relation to additional recovery site(s).
- 2.4. Disaster Recovery Plans. Provider shall implement, maintain, and test disaster recovery plans to minimize downtime resulting from all hazards, including system failure. Provider represents that these disaster recovery plans are documented, tested no less frequently than once every twelve (12) months, and updated as required. The NYPD has a right to review Provider’s disaster recovery plans, and Provider must, upon the NYPD’s request, provide the NYPD with a copy of such plans.

2.5. Data Availability, Storage, and Retention. Provider shall comply with the following:

- 2.5.1. Provider shall ensure that all NYPD Data is available to the NYPD at all times (24/7/365) during the term of the Cloud Services and for a period of ninety (90) days after the term ends, including during any suspension of Cloud Services.
- 2.5.2. All NYPD Data uploaded by the NYPD and stored by Provider shall be available to the NYPD to copy back to the NYPD's storage without alteration or loss and at no additional charge.
- 2.5.3. Provider may not use, access, or perform any analytical analyses of any kind on data derived from the NYPD's usage of the Cloud Service, whether anonymized or aggregated or both, except as agreed to in writing by the NYPD in its discretion, or as required for Provider to provide the Cloud Service.
- 2.5.4. NYPD Data shall not be altered, moved, or deleted without the NYPD's consent;
- 2.5.5. If legal mandates for data retention apply specifically to NYPD Data, Provider shall comply with all such mandates communicated to Provider in writing; and
- 2.5.6. Provider agrees that NYPD Data shall remain in the United States.

2.6. Forensic and Investigative Response. Provider must document and maintain appropriate chain of custody throughout the duration of the delivered services for the purposes of potential forensic or legal investigation. Provider shall not remove metadata, except as directed by the NYPD.

2.7. Access to NYPD Data. Provider shall implement identity and access control policies and procedures in accordance with applicable law and industry best practices, and as approved by the NYPD. Upon the request of the NYPD, Provider shall support federated identity and access management.

2.8. Occurrences Affecting NYPD Data. Provider shall implement, maintain, test and update an incident response plan in accordance with applicable law and industry best practices. Provider represents that (a) prior to delivery of Cloud Services, Provider has provided the NYPD with a copy of its current written incident response plan, and (b) on an annual basis thereafter, Provider shall provide the NYPD with its current written incident response plan. Except as required by applicable law without the possibility of contractual waiver, Provider shall not inform any third party of any Security Incident in the absence of the NYPD's prior written authorization to make the disclosure. The NYPD shall determine whether notice is required to be provided to individuals, regulatory and law enforcement agencies or any other third party and whether any remediation may be offered to individuals affected by the Security Incident.

2.9. Security Incident. In the event of any Security Incident, Provider shall:

- 2.9.1. notify the Department's Security Operations Center ("SOC") by telephone at (646) 610-5690/ via email at infosec@nypd.org and privacyofficer@nypd.org and the Department's Chief Information Security Officer (CISO) within 1 hour.
- 2.9.2. notify the SOC within 1 hour by a written notice directed to the Chief Information Security Officer for the Department at infosec@nypd.org, summarizing, in reasonable detail, the nature and scope of the Security Incident (including a description of all impacted NYPD Data and City Technology Assets) and the corrective action already taken or planned by Provider, which shall

be timely supplemented to the level of detail reasonably requested by the NYPD, inclusive of relevant investigation or forensic reports.

- 2.9.3. promptly, at its own cost and expense, take all reasonable and necessary actions to confirm, contain and end the Security Incident, mitigate its impact to the NYPD, and prevent recurrence.
- 2.9.4. not delete any impacted virtual/cloud instances or re-image any impacted Systems without prior consultation and agreement with NYPD.
- 2.9.5. cooperate with the NYPD in the investigation of the Security Incident, including promptly responding to the NYPD's reasonable inquiries and providing prompt access to all evidentiary artifacts associated with or relevant to the Security Incident, such as relevant records, logs, files, data reporting, and other materials.
- 2.9.6. permit the NYPD, in its sole discretion, to immediately suspend or terminate Provider's right to create, process, access, transfer, store, or dispose of NYPD Data or operate City Technology Assets.
- 2.9.7. not inform any third party that the Security Incident involves City Technology Assets or NYPD Data without first obtaining the NYPD's prior written consent, except to the extent required by law or by third parties engaged by the Provider to remediate the Security Incident.
- 2.9.8. collaborate with the NYPD in determining whether to provide notice that the Security Incident involves City Technology Assets or NYPD Data to any person, governmental entity, the media, or other party, and the content of any such notice. The NYPD will make the final determination as to whether notice will be provided and to whom, the content of the notice, and which Party will be the signatory to the notice.
- 2.9.9. promptly notify the NYPD and the Chief Information Security Officer for the NYPD of any investigations of its data use, privacy or cybersecurity practices, or a Security Incident by a governmental, regulatory or self-regulatory body.
- 2.9.10. bear the responsibility and all related costs for any Security Incident to the extent that the NYPD is not at fault or caused by a vulnerability in the Provider's product(s) or system(s), including the cost of any associated remedial actions or mitigation steps, consumer notification and related responses, credit monitoring, notification, regulatory investigations, fines, penalties, enforcement actions and settlements.
- 2.10. Termination for Security Incident. In the event of a Security Incident that is caused by Provider's failure to comply with the requirements herein, the NYPD may terminate the Cloud Services on no less than fifteen (15) days' prior written notice.
- 2.11. Notice in Event of Provider Receipt of Warrant, Subpoena, or other Governmental Request. If Provider is served with a warrant, subpoena or any other order or request from a court or government body or any other person for any NYPD Data, Provider shall, as soon as reasonably practical and not in violation of law, deliver a copy of such warrant, subpoena, order, or request to the NYPD.
- 2.12. Data Commingling. Provider shall not commingle NYPD Data with non-NYPD Data that is uploaded by Provider, its customers or other third parties and stored by Provider. Provider shall

provide the NYPD with details of how it performs data segregation.

III. DATA PRIVACY AND INFORMATION SECURITY PROGRAM

3.1. Provider Privacy and Security Program. Without limiting Provider's obligation of confidentiality, as further described in this document, Provider shall be responsible for establishing and maintaining a data privacy and information security program ("**Privacy and Security Program**") that includes reasonable and appropriate physical, technical, administrative, and organizational safeguards, to: (a) ensure the security, confidentiality, availability, and integrity of NYPD Data; (b) protect against any anticipated threats or hazards to the security, confidentiality, availability, or integrity of NYPD Data; (c) protect against unauthorized or illegal or accidental disclosure, access to, destruction, alteration, modification, loss, acquisition or use of NYPD Data; (d) ensure the proper disposal of NYPD Data, if requested by the NYPD or required by applicable law; and (e) ensure that all employees, agents, third party providers, and subcontractors of Provider comply with all of the foregoing. Provider shall submit its Privacy and Security Program to the NYPD, and in no case shall the safeguards of such Privacy and Security Program be less stringent than the safeguards used by the NYPD, or such other safeguards as shall be approved by the NYPD Chief Information Security Officer in writing.

3.2. Security Controls. Provider's privacy and security controls must include, but not be limited to, physical, administrative, software, and network security measures, employee screening, employee training and supervision, and appropriate agreements with employees and subcontractors.

3.3. Requirements for Systems Providing Critical Functions. Provider shall provide the NYPD with reports verifying that all patches and configurations are up to date, as well as forecast all required changes for the next twelve (12) months. Provider shall ensure that all necessary capabilities and equipment potentially required to service critical technology in the event of an incident is locally available.

3.4. Treatment of NYPD Data. Provider understands and acknowledges that the NYPD may not be in compliance with nor subject to the General Data Protection Regulation (EU) 2016/279 and its implementing regulations.

3.5. Privacy and Security Audit

3.5.1. Privacy and Security Audit by Provider. No less than annually, Provider shall conduct a comprehensive audit of its Privacy and Security Program and provide such audit findings to the NYPD.

3.5.2. Independent Audit. In addition to the audit required by Section 3.5.1 above, Provider shall engage a third-party internationally recognized auditor (the "**Auditor**"), at Provider's own cost, to perform periodic audits, scans, and tests as follows at least once per year and after any Security Incident that occurs during the term and at the request of the NYPD:

3.5.2.1. a SSAE 18/SSAE 16/SOC-1, Type II audit and a SOC-2, Type II audit of Provider's controls and practices relevant to security, availability, integrity, confidentiality and privacy of NYPD Data;

3.5.2.2. a network-level vulnerability assessment of all Provider systems used to deliver Cloud Services; and

- 3.5.2.3. risk assessment, which may include but is not limited to a formal penetration test of all systems used to deliver Cloud Services; and
- 3.5.2.4. ISO 27001 audit (most current version) and Provider's controls and practices relevant to security, availability, integrity, confidentiality and privacy of NYPD Data.
- 3.5.3. Privacy and Security Audit by NYPD. Without limiting any other audit rights of the NYPD, the NYPD shall have the right to review and audit Provider's Privacy and Security Program and/or IT infrastructure and information security controls and processes prior to the commencement of delivery of Cloud Services and from time to time during the term of the duration of the Cloud Services. As part of the NYPD's right to audit, the NYPD may perform or have a third-party perform relevant tests (e.g., application vulnerability scan or penetration test) to ensure Provider remains compliant with required security policies and standards. NYPD will provide Provider will reasonable prior notice of its request to audit and both parties will negotiate in good faith the timing and other details regarding said audit. Provider shall permit the NYPD to perform such audit, including an audit of the physical security of any of Provider's premises applicable to the Cloud Services provided to the NYPD and shall fully cooperate and furnish all requested materials in a timely manner. The review and audit may be conducted remotely or onsite by the NYPD or a NYPD provider and at the NYPD's expense. The NYPD shall conduct on-site audits in a manner so as not to unreasonably interfere with Provider's business operations. In lieu of an on-site audit, upon request by the NYPD, Provider shall complete, within forty-five (45) calendar days of receipt, an audit questionnaire provided by the NYPD regarding Provider's Privacy and Security Program. Any completed audit report(s) created pursuant to this paragraph will be shared by the NYPD or NYPD's third-party vendor directly with NYPD and Provider. Provider shall not be entitled to compensation from the NYPD for the time it spends cooperating with any of the audits, scans, or tests provided for in this Section, or in completing any audit questionnaire(s).
- 3.5.4. Usage Audit. In the event of a usage audit by Provider, Provider may conduct such audit by itself at its own cost, or engage the services of an Auditor at Provider's own cost. Provider or Auditor shall be bound by confidentiality terms no less stringent than those set forth in this document. In conducting an audit pursuant to this Section, Provider or Auditor may request the NYPD for an analysis of the software the NYPD is running and Provider or Auditor may make copies of any such software logs to the extent necessary to verify the NYPD's compliance with this section. Provider or Auditor shall not run any software on the NYPD's systems, nor shall Provider or Auditor conduct the audit at any of the NYPD's premises. Provider or Auditor shall provide sixty (60) calendar days' notice prior to an audit. Any audit shall be performed during the NYPD's normal business hours and in a manner that minimizes disruption to its business.
- 3.5.5. Findings. Provider shall provide the NYPD with a copy of all reports generated for each audit, scan, and test within ten (10) days after its completion. Each report must: (a) indicate whether any material vulnerabilities, weaknesses, gaps, deficiencies, or breaches were discovered; and (b) if so, describe the nature of each vulnerability, weakness, gap, deficiency, or breach. Provider shall, at its own cost and expense, promptly remediate each vulnerability, weakness, gap, deficiency, or breach that is identified in a report and provide the NYPD with documentation of the remedial efforts within ten (10) days after their completion.
- 3.5.6. Performance Testing. Performance testing is required for all public-facing applications. Provider

must demonstrate the ability to conduct performance testing and establish terms for testing and cost.

3.6. Logs. Provider must generate, maintain, constantly monitor, and analyze security audit logs that contain the information as specified in NIST Special Publication 800-92. If requested by the NYPD, Provider shall provide the audit logs to the NYPD in a format agreed upon by both parties.

3.7. Vulnerabilities. Provider's software applications and any third-party software applications embedded in Provider's software applications must be free from vulnerabilities and defects. Provider must conduct vulnerability scanning for critical systems or systems hosting sensitive data as often as required by law, relevant policy, to maintain certification(s), and in response to the Department of Homeland Security's critical vulnerability/patch publication(s). Provider must provide attestation by an objective third party, stating that the application has been tested for known security vulnerabilities, including, without limitation, those listed in the "OWASP Top-10" as published by the Open Web Application Security Project (see www.owasp.org for current list of the top 10), NIST 800-53 and the NIST Cybersecurity Framework (CSF). If requested by the NYPD, Provider shall also provide the NYPD with information about whether it patched critical vulnerabilities and the remediation steps it took.

3.8. Vulnerability Reporting and Notification Requirement. Provider shall inform the NYPD of any identified vulnerabilities in information systems no later than ten (10) business days after receiving notification. Vulnerability scans should be performed no fewer than once a month. Provider shall provide a monthly report to the NYPD that includes a detailed description of the identified vulnerabilities and a remedial plan with associated timelines informing the NYPD of all actions Provider has taken or plans to take to rectify the vulnerabilities.

3.9. Authorization and Access. Provider's access controls must enforce the following information technology security best practices with respect to its services:

3.9.1. Least Privilege. Provider shall authorize access only to the minimum amount of resources required for a function.

3.9.2. Separation of Duties. Provider shall divide functions among its staff members to reduce the risk of one person committing fraud undetected.

3.9.3. Role-Based Security. Provider shall restrict access to its services to only authorized users. Provider shall base access control on the role a user plays in an organization.

3.9.4. If not utilizing single sign on and Provider's previously authorized resource should no longer have authorization/ access, Provider shall immediately revoke authorization. Provider shall periodically scan for dormant accounts and expeditiously remove/deactivate.

3.10. Change in Service. Provider shall notify the NYPD of any enhancement, upgrade, or other change in the Cloud Service that may impact the security, availability, or performance of the Cloud Services.

IV. VENDOR INDUCED INHIBITING CODE, HARDSTOP/PASSIVE LICENSE MONITORING, MALWARE AND

OTHER DESTRUCTIVE MECHANISMS

Provider shall not include any vendor induced inhibiting code (“**VIIC**”) or any other inhibitor in the Cloud Services or on reports and data submitted and provided to the NYPD. VIIC means any deliberately included application or system code that shall degrade performance, result in inaccurate data, deny accessibility, or adversely affect, in any way, programs or data or use of the Cloud Services. Provider warrants that during the term of the Cloud Services, (a) the Cloud Services will contain no destructive programming that is designed to permit Provider or third parties unauthorized access to, or use of, the NYPD’s systems or networks, or would have the effect of disabling or otherwise shutting down all or any portion of the Cloud Services, and (b) the Cloud Services will contain no viruses, Trojan Horses, worms, spyware, malware, or any other form of malicious code.

V. ENCRYPTION AND AUTHENTICATION

- 5.1. Provider shall encrypt all NYPD Data, including backups, while at rest and in transit from end to end using encryption standards and methods that are approved and recommended by NIST. The NYPD shall have ownership of the encryption keys unless Provider demonstrates to the satisfaction of the NYPD that NYPD ownership is not architecturally feasible.
- 5.2. The use of proprietary encryption algorithms is not allowed for any purpose, unless reviewed by qualified experts outside of Provider and approved in writing by the NYPD Chief Information Security Officer. Proven algorithms must be used as the basis for encryption technologies.
All encryption modules must be FIPS 140-3 certified. Modules certified at FIPS 140-2 which are being submitted for FIPS 140-3 testing are acceptable as an interim solution not to exceed five (5) years of use. At a minimum, the preferred hash algorithm is SHA-2, or any other hashing algorithm defined in FIPS Publication 180-4 (excluding SHA-1). SSL implementations are not acceptable. TLS implementations must be version 1.2 or later, and must use AES for the cipher component and HMAC-MD5, HMAC-SHA1, HMAC-SHA256/384, or AEA for the digest cipher. Provider shall never utilize deprecated, as defined by industry best practices or NIST (whichever is stricter) or weak encryption modules for algorithms.
- 5.3. If the system stores passwords, the passwords must be salted with at least 32 bits of random data and hashed using a one-way key derivation function such as Password-Based Key Derivation Function 2 (PBKDF2) or Balloon. The key derivation function must use an approved one-way function such as FIPS 198-1 (Keyed Hash Message Authentication Code (HMAC)), FIPS 202 (Secure Hash Algorithm 3 (SHA-3)), SHA-3 derived functions outlined in NIST SP 800-185 (Keccak Message Authentication Code (KMAC), Customizable SHAKE (cSHAKE), or ParallelHash), NIST SP200-38B (CMAC), or any approved hash function listed in NIST SP 800-107. The key derivation function should be iterated as much as possible without harming server performance, but in all cases, the function must be iterated at least 10,000 times. If possible, an additional hash with a salt generated by a random bit generator should be stored separately from the hashed password. The random bit generator must be listed in NIST SP 800-90Ar1, and must provide at least the minimum security strength specified in the latest revision of NIST SP 800-131A.
- 5.4. Shared keys used for IPSec tunnels must be complex, randomly generated pursuant to Section 5.3, and not be stored for later reference. During initial setup of an IPSec tunnel, the shared key must be transmitted out of band to the other party involved. Provider must utilize cryptographic algorithms that are acceptable to the NYPD.

5.5. Digital Certificates that validate and secure communications used by the general public must be generated by trusted third-party providers. Certificates that validate communications used by internal NYPD employees or business partners and/or web applications can be generated by the NYPD Certificate Authority (internal PKI) or third-party providers.

VI. NYPD SECURITY REVIEW OF PROVIDER'S CLOUD SERVICES

6.1. The Cloud Services may be subject to a security review by the NYPD. If such a security review has been completed and the NYPD's written disposition requires Provider to comply with the NYPD's prescribed security measures ("**NYPD Security Measures**"), then, in addition to complying with the requirements of this document, Provider shall comply with the NYPD Security Measures.

6.2. Any written disposition of a security review by the NYPD shall not be deemed to constitute an endorsement of the Cloud Services or a certification that the Cloud Services meet the NYPD Security Measures or the requirements under this document. Provider remains fully responsible for ensuring compliance with the NYPD Security Measures and this document. At all times during the term of the Cloud Services, Provider agrees to cooperate with the NYPD to ensure that Provider is in compliance with all NYPD Security Measures and the provisions of this document.

6.3. Following the review and written disposition described in Sections 6.1 and 6.2 above, Provider agrees to submit all devices, applications, systems, software and infrastructure used to support NYPD systems to the NYPD's applicable security testing process. The NYPD's security testing process may include a formal application scan (in staging) and/or a penetration test of Provider's Cloud Services and any required remediation. Provider understands and acknowledges that failure to meet the NYPD's security requirements is a material breach of this document.

6.4. Prior to any application scan or penetration test, Provider shall execute any waiver that may be required by the NYPD.

VII. DATA OWNERSHIP

7.1. The NYPD retains sole ownership and Intellectual Property Rights in and to all NYPD Data. Provider shall not use the NYPD Data for any purpose other than as required to provide the Cloud Services to the NYPD.

7.2. Provider shall not retain any NYPD Data after a ninety (90) day period following the expiration/termination of the term or following the NYPD's request pursuant to Section 7.1.

7.3. The NYPD hereby retains all right, title, and interest in and to any suggestion, enhancement request, recommendation, correction or other feedback provided to Provider relating to Provider's Cloud Services, except that Provider may use such information in connection with its provision of Cloud Services to the NYPD. Any feedback from the NYPD is provided "as is", and the NYPD disclaims any and all warranties whatsoever.

7.4. Except as expressly provided in this document, no ownership right or license to use, sell, exploit, copy or further develop NYPD Data, any confidential information or Intellectual Property of the NYPD is conveyed to Provider.

VIII. NO SUPPLEMENTARY AGREEMENTS OR TERMS; NO UNILATERAL CHANGES; APPLICABILITY.

- 8.1. All click-through, click-wrap, or shrink-wrap agreements or other end user terms and conditions that are embedded in or provided with any of Provider's Cloud Services or presented to users in the course of the NYPD's use of the Cloud Services are not applicable to the NYPD, even if use of Provider's Cloud Services require an affirmative acceptance of those terms.

IX. SEPARATION ASSISTANCE

- 9.1. In the event of impending or actual separation (due to impending or actual expiration or earlier termination of the Cloud Services, whenever that may occur) and for up to ninety (90) days following such expiration or termination, the NYPD may request in writing that Provider do or permit the NYPD to do any of the following, or any combination of the following:
- 9.1.1. Export and/or copy NYPD Data. If the NYPD requests an export of NYPD Data, such exported data shall be in a format approved by the NYPD in writing.
 - 9.1.2. Destroy any NYPD Data. Any written request by the NYPD directing Provider to destroy NYPD Data shall specify what data the NYPD is requesting to be destroyed. Provider shall not destroy any NYPD Data in the absence of a specific written request from the NYPD. If Provider destroys any NYPD Data, it shall verify such destruction in writing. Destruction of NYPD Data shall be performed by Provider in a manner that complies with NIST and precludes recovery or reconstruction of such data by all currently known methods and technology. Unless otherwise specified by the NYPD, a request to destroy NYPD Data includes destruction of live/production data as well as data housed as/in backup(s).
 - 9.1.3. When applicable, upon the NYPD's request, Provider shall verify it has turned off the NYPD's access to the Cloud Services.
- 9.2. At no cost to the NYPD, Provider must provide separation assistance to the NYPD to perform or support the exporting, copying, and/or destruction of NYPD Data in accordance with the NYPD's written request.

X. CONFIDENTIALITY

- 10.1. Provider agrees to hold confidential, both during and after the completion or termination of the agreement for Cloud Services, all NYPD Data and Non-Public City Data. Provider shall use NYPD Data and Non-Public City Data for no purpose other than providing the Cloud Services in accordance with such agreement.
- 10.2. Provider agrees to maintain the confidentiality of the NYPD Data and Non-Public City Data by using a reasonable degree of care, and at least the same degree of care that Provider uses to preserve the confidentiality of its own confidential information.
- 10.3. Provider agrees that NYPD Data and Non-Public City Data shall not be made available to any person or entity without the prior written approval of the NYPD, except that Provider may disclose NYPD Data and Non-Public City Data to its employees, officers, agents and consultants ("**Representatives**") on a need-to-know basis. Provider shall ensure that its Representatives are bound by confidentiality obligations no less stringent than those in this document, and shall be liable for a breach by its Representatives of the foregoing confidentiality obligations.

10.4. The obligation under this section not to disclose NYPD Data and Non-Public City Data shall not apply where Provider is legally required to disclose such reports, information or data, by virtue of a subpoena, court order or otherwise (“**disclosure demand**”), provided that Provider complies with the following: (a) Provider shall provide advance notice to the Commissioner, in writing or by e-mail, that it received a disclosure demand for to disclose such reports, information or data, (b) if requested by the NYPD, Provider shall not disclose such NYPD Data and Non-Public City Data until the NYPD has exhausted its legal rights, if any, to prevent disclosure of all or a portion of such Data, and (c) Provider shall reasonably cooperate with the NYPD in minimizing the NYPD Data and Non-Public City Data disclosed. The previous sentence shall not apply if Provider is prohibited by law from disclosing to the NYPD the disclosure demand for such NYPD Data and Non-Public City Data.

XI. ADDITIONAL SECURITY REQUIREMENTS

11.1. NYPD Information Security Policy. Provider shall comply with the NYPD policies and standards. In addition, Provider shall ensure that all subcontractor(s) approved by the NYPD in writing (each an “**Authorized Subcontractor**”) and any employee of Provider or an Authorized Subcontractor who needs to know the NYPD Data in order to perform Provider’s obligations (each an “**Authorized Person**”) who may have access to any NYPD Data or City Technology Assets in the course of carrying out their responsibilities or job functions comply with this Section 11.1. Provider shall be liable for the breach by an Authorized Subcontractor or Authorized Person or any of its subcontractors or persons who are not considered Authorized Subcontractors or Authorized Persons.

NYPD Logical System Access Certification (“Access Certification”). Provider shall require, when applicable, each Authorized Person who may have access to any NYPD Data to submit an Access Certification request and to sign a written acknowledgement and agreement to comply with its terms prior to his or her assignment to perform any Services pursuant to the Cloud Services. Providers are encouraged to submit the access control package as soon as candidates are identified. Please be advised that candidates will not be able to work on NYPD systems or access the NYPD network until the background check and CJIS training has been completed.

11.2. shall provide a signed copy of the Access Certification acknowledgement for each Authorized Person to the Department CISO, within fifteen days (15) days after the Authorized Person is assigned to perform Services pursuant to the agreement to provide Cloud Services.

11.3. Non-Disclosure Agreement. If requested by the NYPD, Provider shall require its Authorized Subcontractors and Authorized Persons who either work in direct support of the Cloud Services or who may reasonably be anticipated to receive NYPD Data to execute a Non-Disclosure Agreement in a form acceptable to the NYPD.

11.4. Cooperation with Accreditation. Provider shall cooperate with and facilitate the successful completion of any security accreditation tasks and processes relevant to the Cloud Services it provides. Provider shall complete said security accreditation tasks and processes within thirty (30) business days unless granted an extension by the NYPD.

11.5. Provider Security Questionnaire. Provider shall complete and respond to all security questionnaires from the NYPD within thirty (30) business days.

11.6. Noncompliance Self Reporting Requirement. Provider shall notify the NYPD of any changes to the infrastructure of all information systems that would affect NYPD Data or result in

noncompliance with any federal or state law, Policies and Standards, or terms of this document. Notification of each change shall be made to the NYPD no later than three (3) business days after the change has occurred. For noncompliance, Provider shall submit to NYPD a document that includes the following: (a) date of discovery; (b) how the noncompliance was identified; (c) nature of the noncompliance; (d) scope of noncompliance; and (e) corrective actions with associated timelines.

11.7. Remote Access Methods. Provider must obtain written permission from the NYPD for each instance of remote access it wishes to use and access NYPD Data.

11.8. Warranties and Representations.

11.8.1. Intellectual Property. Provider represents and warrants that it has the rights necessary to provide the Cloud Services to the NYPD.

11.8.2. Additional Warranties and Representations. Provider further represents and warrants that: (a) the Cloud Services shall be provided in a professional, competent, and timely manner by appropriately qualified personnel in accordance with this Agreement and consistent with Provider's best practices; (b) Provider shall provide adequate training, as needed, to the NYPD on the use of the services; (c) the Cloud Services shall comply with all applicable international, federal, state, and local laws, rules, and regulations, including but not limited to laws relating to privacy, security, and anti-corruption; (d) the Cloud Services does not and shall not infringe the Intellectual Property Rights of any third party; (e) the Cloud Services are compatible and shall maintain compatibility with third party software, including any OSS; (f) there is no pending or threatened litigation involving Provider that may impair or interfere with the NYPD's right to use the services; and (g) Provider has sufficient authority to enter into this Agreement and grant the rights provided in such Agreement to the NYPD.

11.9. Publicity. Provider shall not distribute any media releases or making other public announcements relating to this document or the existence of the relationship or negotiations between the Parties, or otherwise using the NYPD's name and trademarks without the NYPD's prior written consent.

11.10. Use of Third Party Providers

11.10.1. Provider must identify any third-party entities involved in the provision of the Cloud Service and provide the NYPD with a copy of Provider's agreement with the third-party provider. The agreement must be approved in writing by the NYPD. Provider shall notify the NYPD in the event that Provider makes any change in the list of third-party providers that it uses prior to making any change along with a copy of any applicable terms. Notwithstanding the NYPD's approval of such third party provider agreements, (a) Provider shall remain responsible for any and all performance required under this document, including, but not limited to, the obligation to properly supervise, coordinate, and perform, all work required hereunder, and no third party provider agreement shall bind the NYPD; and (b) Provider shall ensure that any third party provider complies with the requirements herein. If Provider proceeds with an unapproved third-party provider, it shall be deemed liable to the NYPD for any third-party claims to the same extent as the third party provider would have been liable had it agreed to the terms set forth in this Agreement.

11.10.2. Any subcontractor or Affiliate (as defined below) of Provider that provides any software

or services in connection with the Cloud Services is deemed to be a subcontractor whose subcontracts must be approved in writing by the NYPD. As used in this paragraph, “Affiliate” means any parent, subsidiary or other entity that is (directly or indirectly) controlled by, or controls, Provider.

- 11.10.3. Provider must confirm that Cloud Services do not require the use of TikTok on City owned Device(s) and Network(s) in the performance of the contract, except in cases of Approved Exception(s).

11.11. Cyber Insurance

- 11.11.1. Data Breach and Privacy Cyber Liability. Provider shall maintain at all times during the provision of Cloud Services, and as otherwise required herein, data breach and privacy cyber liability insurance with limits of no less than \$10,000,000 per claim and \$20,000,000 in the aggregate. This policy must include coverage for:

11.11.1.1. failure to protect confidential information, including personally identifiable information;

11.11.1.2. failure of the security of Provider’s computer systems;

11.11.1.3. failure of the security of the NYPD’s systems or NYPD Data due to the actions or omissions of Provider;

11.11.1.4. Data breach expenses, including forensic services, the cost of complying with privacy laws and regulations, cost of undergoing regulatory examinations and defending regulatory actions, including legal representation, cost of internal investigation to determine the cause of the breach, notification costs, public relations and crisis management costs, credit monitoring, fraud consultation, credit freezing, fraud alert, and identity restoration services;

11.11.1.5. Costs arising from cyber extortion threats, including the payment of ransom demands;

11.11.1.6. The alteration, loss, corruption of data, including costs to recover, correct, reconstruct, and reload lost, stolen, or corrupted data;

11.11.1.7. The cost of replacing, repairing, or restoring computer systems, including hardware (including laptops and mobile devices), software, networking equipment, and storage;

11.11.1.8. Costs arising from an attack on a network or computer system, including denial of service attacks, malware, and virus infections;

11.11.1.9. Dishonest, fraudulent, malicious, or criminal use of a computer system by a person, whether identified or not, and whether acting alone or in collusion with other persons;

11.11.1.10. Media liability; and

11.11.1.11. Cyber theft of customer's property, including but not limited to money and securities.

11.11.2. Technology Errors and Omissions. Provider shall maintain at all times during the provision of Cloud Services, and as otherwise required herein, technology errors and omissions insurance covering Provider in the amount of at least \$10,000,000 per occurrence and \$20,000,000 in the aggregate for damages arising from computer related services, including, but not limited to, one or any combination of the following: (a) consulting, (b) data processing, (c) programming, (d) system integration, (e) hardware development, (f) software development, (g) installation, (h) distribution or maintenance, (i) systems analysis or design, (j) training, (k) staffing or other support services, (l) cloud computing services, and (m) any electronic equipment, computer software developed, manufactured, distributed, licensed, marketed or sold. This policy must include coverage for third-party fidelity, including cyber theft.

11.12. Open Source Software. If the Cloud Services consist of any Open Source Software, Provider shall, upon request, furnish the NYPD with the applicable OSS licensing terms (the "**Licensing Terms**"). Provider shall be responsible for all third party software and OSS incorporated in the Cloud Services. If the Cloud Services do not utilize any OSS, Provider shall affirm such in writing to the NYPD in advance of its processing of any order for such Cloud Services.